



— C O M P A N I O N D O C U M E N T • V 1 . 0

Security Review and Remediation Annex

The complete independent security and architecture review of HUGS ID™ Technical Specification v1.0, retained in full, with the disposition of every finding recorded in v1.1 Section 12.

Document	HUGS ID™ Security Review and Remediation Annex
Version	1.0
Publication date	4 August 2026
Reviews	HUGS ID™ Technical Specification v1.0 (Public Working Draft)
Dispositioned by	HUGS ID™ Technical Specification v1.1, Section 12
Canonical reference	hugsid.com • learn.xpguess.com

1. About This Annex

This annex retains, in full, the independent security and architecture review of the HUGS ID™ Technical Specification v1.0 (Public Working Draft). The review was produced by an automated multi-agent audit pipeline (eight-stage hunt-and-validate process), then hand-vetted and clustered by root cause. Thirty-two findings survived the pipeline's adversarial validation stage, in which candidate findings were actively challenged; ten further candidate findings were rejected at that stage as already addressed by the specification text. The surviving findings reduce to the ten themes reproduced in Section 2 of this annex.

The review text is reproduced faithfully; severity labels and headings have been formatted for readability, and the disposition of every theme is recorded in the companion specification, HUGS ID™ Technical Specification v1.1, Section 12 (Security Review Disposition). This annex is engineering guidance, not legal advice; a data protection impact assessment and privacy counsel review remain required before implementation.

2. Review Findings

2.1 Bottom Line

The specification is architecturally sound and unusually mature for a working draft — clean 7-layer separation, first-class consent and revocation, an explicit AI-permission model, T0–T4 trust levels, and it correctly keeps PII in source systems. Almost every finding is a missing cryptographic mechanism or a missing enforcement requirement, not a structural mistake. In other words: the design says the right things (“verifiable authority chain”, “attested”, “signed”, “privacy-preserving”) but a Public Working Draft has not yet defined the machinery that makes those words true. For a v1.0 draft that is expected — this review is the punch-list to close before anyone implements it, especially because the first domain governs minors' data.

The one theme that rises to critical, and the four high-severity themes most worth fixing first, all share a spine: nothing in the specification is cryptographically bound to a key. Authority chains, verifications, evidence, identities, and AI attribution are all records an implementation is trusted to have produced honestly. Bind them to keys and the majority of the findings close at once.

2.2 Theme 1 — Authority Chains Have No Cryptographic Construction

CRITICAL

Root cause behind five findings: chain forgery, amplification, T3 spoofing, revocation race, trust-component gaming.

The Authority Chain is the root of all governed authorization — every governed operation must trace to a complete authority chain, policies are issued under one, and the T3 “Certified” trust level (required for decide-class AI actions over athletes, including minors) is defined solely as attestation by the governing body through a complete authority chain. Yet v1.0 defines a chain only as “a verifiable, ordered sequence of delegations” and, uniquely among the governance objects, gives it no field table: no per-link signature, no root-of-trust key set, no per-link scope or capability fields, no expiry, no signed revocation state.

Consequences an implementation faithful to the v1.0 text cannot prevent:

- Forgery — any authenticated actor submits a self-authored chain record naming themselves the terminal party; with no signatures to check, the evaluator grants authority over a minor's data.
- Amplification — a downstream link records action or data classes no ancestor held; there is no defined authority set against which to compare parent and child.
- T3 spoofing — a forged chain manufactures the “Certified” level that unlocks automated eligibility and selection decisions.
- Stale-link replay — re-presenting a previously valid record, with no freshness to bind revocation to.

Fix — Define an Authority Chain object where each link is a signature by the parent over

(child_identity, delegated_scope, delegated_actions, expiry); a published, rotatable framework root key; a MUST that verification reject any chain not rooted at a recognized root; per-link scope and actions fields drawn from the Policy and Consent vocabularies plus a subset (attenuation) check; and signed revocation and freshness. — Dispositioned in v1.1 Section 5.3 (REQ-5-1 through REQ-5-5).

2.3 Theme 2 — Nothing Is Bound to a Key

HIGH

Six findings: identity-to-key binding, proof optional, Verification Object unsigned, evidence substitution, unattributed AI action, self-attestation gaming.

- No key is bound to a hugs:id. The Canonical Identity Object's MUST fields carry no verification method or public key; the only cryptographic field, proof, is SHOULD and scoped to object-byte tamper-evidence, not actor control. Authentication is then delegated entirely to OAuth 2.0 / OpenID Connect bearer tokens, so proof of control over an identity reduces to possession of a token — a leaked, replayed token or a misconfigured identity provider fully impersonates an identity, including a guardian of a minor's record.
- The Verification Object has no schema and no signature, yet it is the input from which trust levels are computed. A single compromised verifier can forge an attestation naming a governing body it never involved and inflate a minor's claim to T3.
- Evidence Records feeding verification are not integrity-bound, permitting substitution.
- AI attribution — the four-element tuple that makes unattributed AI operation non-conformant — is never required to be signed, so it is self-reported and forgeable.
- “Independent sources” for trust depth is undefined, so one actor's multiple attestations can count as multi-source.

Fix — Elevate proof to MUST on identities, Verification Objects, and Authority Chain links; bind at least one public key to every hugs:id and require proof of possession (signed challenge, DPoP, mTLS-bound tokens, or verifiable-credential holder binding) for governed operations rather than bearer possession; define “independent source” as distinct root authorities. — Dispositioned in v1.1 Sections 4.1, 4.5, 9.3, and 10.2.

2.4 Theme 3 — Guardianship over a Minor Is Asserted, Never Verified

HIGH

Two findings — the most consequential for the Athlete Intelligence use case.

The controller of an individual is “the person, or a legal guardian where applicable,” and the consent grantor is “the controller or authorized delegate” — but v1.0 nowhere defines how guardianship over a minor is proven or bound to that minor's identity. The controller field is a bare URI asserted at registration, and authority chains model only institutional delegation, never guardian-to-minor. So any

authenticated actor can register a minor's identity with themselves as controller, then grant model-training, media-licensing, or selection-evaluation consents over that minor's verified data. This defeats the exact legal basis — COPPA and GDPR Article 8 verifiable parental consent — the design leans on.

Fix — Require that for any consent whose subject is a minor, the grantor's guardianship be established by a verification from a competent authority, bound into the subject's record, revalidated on revocation, and required before the consent is valid. — Dispositioned in v1.1 Section 6.5 (Guardian Relationship Verification Object; REQ-6-3 through REQ-6-5).

2.5 Theme 4 — AI-Permission Safeguards Are Documentary, Not Enforced

HIGH

Four findings: decide-class human review, blanket authorization, synthetic-media labeling, re-derivation after revocation.

The controls exist on paper but the v1.0 wording lets a conformant implementation skip them:

- Decide-class actions (automated selection, eligibility, pricing on minors) require only that a human review path be “defined” — never exercised, logged, or offered to the subject. An operator documents an on-paper process, never invokes it, and makes fully unreviewed automated decisions about minors while passing conformance.
- The prohibition on “blanket authorizations” defines no boundary separating a standing consent from a de-facto blanket grant.
- Synthetic-media labels — the anti-deepfake defense — are not required to be tamper-evident or cryptographically bound to the content; strip the label, lose the provenance.
- Re-derivation after revocation is prohibited with no mechanism to detect or prevent it.

Fix — Change “human review path defined” to MUST be exercised for decide-class actions affecting a subject (mandatory for minors), with a Decision Record capturing reviewer identity, timestamp, and disposition in the Event Log, plus subject or guardian notification and a contestation right; make “defined but never invoked” explicitly non-conformant; bind synthetic-media labels cryptographically (C2PA-style) to the asset. — Dispositioned in v1.1 Sections 8.3 through 8.5 (REQ-8-3 through REQ-8-6).

2.6 Theme 5 — Privacy Doesn't Hold for Minors

HIGH

Three findings: correlation, sensitive data, erasure.

- Re-identification: the design mandates a single persistent, globally resolvable identifier that persists across teams, schools, leagues, and countries. Excluding names and birthdates from the object does not stop correlation — any two relying parties who each legitimately saw a minor's hugs:id can join

their records by that shared key into a longitudinal cross-border profile. No pairwise or sector-specific pseudonymous identifiers are defined.

- Sensitive minor data: the development data class (combine results, testing-body results) is biometric and physiological data about children, governed with no elevated safeguard.
- Erasure versus immutability: every governed action writes an immutable Event Log entry binding the action to an identity — colliding head-on with the GDPR and COPPA right to erasure for a minor.

Fix — Mandate pairwise pseudonymous subject identifiers so the resolvable identifier is never shared directly with relying parties; add an explicit unlinkability requirement threat-modeled against minors; anchor only non-personal, salted references in the immutable log so erasure is possible; elevate biometric and development data to a sensitive class with express, revocable, guardian-verified consent. — Dispositioned in v1.1 Sections 4.6 and 6.6 (REQ-4-6 through REQ-4-8, REQ-6-6, REQ-6-7).

2.7 Theme 6 — API Authorization Scope Is Named but Undefined

HIGH

Four findings: event-log IDOR, identity search enumeration, policy-publish authorization, status-code oracle.

GET /v1/events filters “by the caller's authorization scope” — a term never defined anywhere. GET /v1/identities allows search with no result scoping, enabling enumeration of minors' identities. Nothing constrains who may publish policies at which scope. And the status-code taxonomy distinguishes consent_denied from policy_denied from not_found finely enough to serve as an inference oracle.

Fix — Define authorization scope normatively; add an object-level authorization MUST on every read, search, and publish resource; collapse security-sensitive status distinctions. — Dispositioned in v1.1 Sections 10.2 and 10.4 (REQ-10-2).

2.8 Theme 7 — Webhook Delivery Is an SSRF and Exfiltration Surface

HIGH / MEDIUM

Two findings.

V1.0 defines outbound webhooks with no callback-URL validation. An authenticated subscriber registers a cloud metadata address or an internal host; the framework's own trusted delivery agent then makes attacker-directed requests on every governed event, yielding classic server-side request forgery and exfiltration of event payloads carrying minors' identity, consent, and verification data. Signing the payload authenticates the sender — it does nothing to constrain the destination. Separately, the signature scheme itself is undefined: no algorithm, key distribution, rotation, or replay protection.

Fix — Require that callback URLs use https, resolve to public non-reserved IPs (blocking loopback,

RFC 1918, link-local, and metadata ranges), re-validate the pinned IP at delivery against DNS rebinding, and deliver from an egress-restricted path with no ambient credentials; and fully specify the signature suite with algorithm agility, key rotation, and timestamp-plus-nonce replay protection. — Dispositioned in v1.1 Section 10.6 (REQ-10-3, REQ-10-4).

2.9 Theme 8 — Check-to-Use Has No Atomicity or Fail-Closed Default

HIGH / MEDIUM

Three findings: *identity-status TOCTOU*, *consent-at-use TOCTOU*, *revocation-to-recompute race*.

Revocation “MUST trigger recomputation of dependent scores” and consent “MUST be verified at the time of each use” — but with no latency bound, no atomicity, and no fail-closed default during the recomputation window. A revoked verification, suspended identity, or withdrawn consent can still authorize an in-flight operation in the gap between check and use.

Fix — Require the consent and authority check and the protected use to be atomic, or fail closed during any pending re-evaluation, with a bounded, auditable propagation SLA on revocation. — Dispositioned in v1.1 Section 10.7 (REQ-10-5, REQ-10-6).

2.10 Theme 9 — Identifier Entropy Is Underspecified

MEDIUM

The unique identifier MUST be “collision-resistant” but no minimum entropy, length, or algorithm is given, and the specification's own normative example is short and guessable (roughly 48 bits of visible entropy).

Fix — Mandate at least 122-bit random identifiers (UUIDv4 or a 128-bit CSPRNG value) and correct the example. — Dispositioned in v1.1 Section 4.2 (REQ-4-0).

2.11 Theme 10 — Media-Rights Consent Semantics Gap

HIGH / MEDIUM

Media licensing is asserted to run “under media-licensing consents with explicit revocation semantics,” but the Consent Object does not specify the redistribution, sublicensing, or downstream-propagation terms that make revocation of already-distributed likeness meaningful.

Fix — Define redistribution and downstream-revocation-propagation fields for media-rights consents. — Dispositioned in v1.1 Section 6.1 (redistribution, sublicense, downstream_revocation).

3. What the Review Got Right, and Its Limits

- Real filtering happened. Ten candidate findings were rejected by the adversarial pass with correct reasoning — for example, a claimed insecure direct object reference was dropped because the specification does gate that resource elsewhere, and a lifecycle race was dropped because the lifecycle table separates “resolvable” from “operable.” The surviving findings are not raw model output; they survived a disprove-it pass.
- Limits, stated plainly. First, all agents ran on a single model, so the pipeline's usual cross-model disagreement was reduced to same-model adversarial re-reading; a few “underspecified” flags sit close to the line between a real gap and what a working draft reasonably leaves to implementers (these are marked medium). Second, the review assessed the specification text, not an implementation — there is no running code, so the findings are design-level, and some remedies (SSRF egress restriction, status-code uniformity) are things a specification should mandate but code must ultimately enforce. Third, the run was salvaged from artifacts after an infrastructure failure during the final formatting stage; the findings and their adversarial verdicts are complete, and only the tool's auto-generated summary was regenerated by hand.
- Framing. This is a punch-list for a strong draft, not a teardown. The theme is consistent and encouraging: bind it to keys, and require the checks the design already describes. Remedying themes 1 through 5 — authority-chain cryptography, key binding, guardian verification, enforced AI safeguards, and minors' privacy — before implementation takes HUGS ID from a credible-sounding framework to a defensible one.

Design-level review of the HUGS ID Technical Specification v1.0 (Public Working Draft). Findings survived an adversarial validate pass; severities reflect consequence for a framework governing minors' verified data. Engineering guidance, not legal advice — a DPIA and privacy counsel are still required before implementation.